

DEFECT / ISSUE NOTES

Issues & Observations Found During QA Checklist Review

Document Type	Defect / Issue Notes
Version	1.0
Application	Student Registration System
Prepared By	Ruknuddin Asrari
Email	ruknuddin.asrari@thecareerinsights.com
Job Title	Software Quality Engineer
Department	IT Software Development
Organisation	The Career Insights Hub LLC
Date	2026
Build Version	Build-1.0
Total Defects	6 (Critical + High from checklist review)
Total Observations	8 (WARN items requiring attention)

Prepared by Ruknuddin Asrari | ruknuddin.asrari@thecareerinsights.com | Software Quality Engineer | The Career Insights Hub LLC

1. Overview

This document records all defects and observations identified during the execution of the QA Checklist for the Student Registration System. It consolidates findings from the functionality, validation, usability, security, and performance checks into a prioritised action list for the development team.

Severity	Count	Checklist Items
Critical	5	FC-002, FC-008, FC-014, FC-026, VC-010
High	5	FC-009, FC-010, FC-013, VC-002, VC-007
Medium	4	FC-018, FC-020, VC-004, VC-005
Low	3	UC-009, UC-010, UC-012
TOTAL (FAIL)	14	FC-002 to QS-014
Warnings (WARN)	13	VC-004, UC-007, QS-002, QS-005, QS-008, and others

2. Critical & High Defect Notes

DN-001 Authentication Completely Bypassed — Login Accepts Wrong Password		
Severity: Critical	Priority: P1 – Fix Immediately	Checklist Ref: FC-008 / VC-010 / QS-003
Observed Behaviour	During login testing, entering a registered email with an incorrect password resulted in a successful login. The system created a full authenticated session and redirected the user to the student dashboard as if credentials were valid.	
Impact	Any user with knowledge of a registered email can gain unauthorised access to any student account without knowing the password. This is a complete authentication failure and the most critical defect in the system.	
Recommended Action	Investigate the authentication logic immediately. Verify the password comparison function — a common cause is bcrypt compare returning true incorrectly or the check being skipped. Fix, deploy, and retest TC-009 to TC-017 in full.	

DN-002 Student Role Accesses Admin Dashboard via Direct URL — RBAC Not Enforced		
Severity: Critical	Priority: P1 – Fix Immediately	Checklist Ref: FC-026
Observed Behaviour	A student account navigated directly to /admin/dashboard via the browser URL bar. The page loaded fully with all admin features — student list, course management, reports — accessible without any error or access restriction.	
Impact	Role-based access control exists only at the UI level. Any student can access and potentially manipulate admin-only data and functions. This is a critical security gap that exposes the entire system to unauthorised data manipulation.	
Recommended Action	Implement server-side middleware or route guards that verify the user's role on every request to an admin-prefixed route. Return HTTP 403 for unauthorised access. Audit all protected routes and retest TC-039.	

DN-003 Enrollment Data Integrity Failures — Negative Seat Count & Duplicate Enrollment		
Severity: Critical	Priority: P1 – Fix Before Release	Checklist Ref: FC-014 / VC-010 / FC-013
Observed Behaviour	Two enrollment defects observed: (1) Enrolling when capacity = 0 succeeded — available seats decremented to -1. (2) Enrolling in an already-enrolled course succeeded — duplicate record created in the database.	
Impact	Academic enrollment data is corrupt. Students appear enrolled in courses they should not be in. Seat counts are negative — meaningless for reporting. Database integrity is compromised for the core function of the system.	
Recommended Action	(1) Add a capacity check before any enrollment insert — reject if seats = 0. (2) Add a unique composite constraint on (student_id, course_id) in the enrollment table. Test both fixes with boundary and concurrent scenarios (TC-020, TC-021, TC-041).	

DN-004 Multiple Authentication Security Gaps — Duplicate Account, No Lockout, Session Persistence		
Severity: High	Priority: P1 – Fix Before Release	Checklist Ref: FC-002 / FC-009 / FC-010
Observed Behaviour	Three related authentication issues: (1) Duplicate email registration creates second account — no uniqueness check. (2) No account lockout after 5 wrong password attempts. (3) Pressing browser back after logout restores the authenticated dashboard.	
Impact	Collectively these gaps allow account duplication, enable brute-force password attacks, and allow session hijacking via browser history. The authentication system is not production-ready.	
Recommended Action	(1) Add DB-level unique constraint on email + server-side check on signup. (2) Implement failed-attempt counter with 15-minute lockout after 5 failures. (3) Destroy session server-side on logout — add Cache-Control: no-store headers. Retest TC-009 to TC-017.	

DN-005 No Server-Side Input Validation — Weak Passwords and API Bypass		
Severity: High	Priority: P1 – Fix Before Release	Checklist Ref: VC-002 / VC-007
Observed Behaviour	Weak passwords ('123456', 'password') are accepted through the UI. When the signup API endpoint is called directly (bypassing the frontend), all validation rules are ignored — invalid emails, short passwords, and empty fields are all accepted.	
Impact	The application's data quality depends entirely on the browser. Any direct API call can create accounts with garbage data. Weak passwords create brute-force vulnerabilities for all user accounts.	
Recommended Action	Move all validation logic (email uniqueness, password complexity, required fields) to the backend API layer. Frontend validation should remain as UX enhancement only — never as the sole enforcer. Test via Postman direct API calls.	

DN-006 Profile Module — Oversized File Upload Accepted & Required Field Not Enforced		
Severity: Medium	Priority: P2 – Fix Next Sprint	Checklist Ref: FC-018 / FC-020
Observed Behaviour	(1) Profile photos up to 15MB uploaded successfully — 5MB limit not enforced. (2) Last Name field can be cleared and saved — null value stored in database.	
Impact	Oversized uploads consume unnecessary server storage and may slow page loads for other users. Empty Last Name breaks profile display in the admin dashboard and any name-based search or reporting functions.	
Recommended Action	(1) Add file size check (max 5MB) on the server — reject with 413 or custom error. Also validate file MIME type. (2) Add NOT NULL constraint and required validation for Last Name on the backend. Retest TC-029 and TC-030.	

3. Warning Observations & Notes

The following observations were logged as WARN during the checklist review. These are not blocking defects but represent quality or risk items that should be addressed in the next available sprint.

Ref	Observation	Risk Level	Scheduled Action
OBS-001	Browser compatibility testing incomplete — Chrome only tested	Medium	Execute test matrix on Firefox 121 and Edge 120 — target next sprint
OBS-002	Session expiry timeout configured but not invalidated server-side on logout	High	Linked to DN-004 — resolve as part of session fix
OBS-003	CSRF protection not verified on all API endpoints	High	Audit all POST/PUT/DELETE endpoints for CSRF token enforcement
OBS-004	JMeter load test not yet executed for 50+ concurrent users	High	Schedule load test pre-release — block release if SLA not met
OBS-005	Some input fields do not enforce maximum character length	Medium	Define max-length attributes and server-side limits for all fields
OBS-006	File type validation for photo upload not fully tested	Medium	Test upload of .pdf, .exe, .svg files — confirm rejection
OBS-007	404 error page lacks navigation link back to home or dashboard	Low	Add 'Go to Home' button to 404 and generic error pages
OBS-008	No loading indicator during course enrollment submission	Low	Add spinner/loader to prevent accidental duplicate submissions

4. Action Priority Matrix

Action	Owner	Priority	Target
Fix authentication — password check + logout + session	Dev Team	P1 – Critical	Immediate
Enforce server-side RBAC on all admin routes	Dev Team	P1 – Critical	Immediate
Fix enrollment capacity check + duplicate enrollment constraint	Dev Team	P1 – Critical	Immediate
Add server-side input validation (all forms + API)	Dev Team	P1 – High	Current Sprint
Fix duplicate email registration	Dev Team	P1 – High	Current Sprint
Execute regression suite on fixed build	QA Engineer	P1 – High	After dev fixes
Fix profile Last Name + file size validation	Dev Team	P2 – Medium	Next Sprint
Execute cross-browser test matrix	QA Engineer	P2 – Medium	Next Sprint
Execute JMeter load test at 50+ users	QA Engineer	P2 – High	Pre-release
Audit and fix CSRF protection on API endpoints	Dev Team	P2 – High	Next Sprint

Action	Owner	Priority	Target
Resolve all OBS-001 to OBS-008 observations	Dev + QA	P3 – Low/Med	Following Sprint

Prepared by Ruknuddin Asrari (ruknuddin.asrari@thecareerinsights.com) | Software Quality Engineer | The Career Insights Hub LLC
| 2026